

Rails Health Audit — example-unhealthy-project

Generated 2026-06-23 15:49. Static scan + (best-effort) runtime checks. Full raw tool output is in `raw_original_result/`.

1. Overview (every check, most severe first)

Priority	Category	Tool	Finding	Raw output
 1	Security	brakeman	4 warning(s)	<code>raw_original_result/brakeman.txt</code>
 1	Security	bundler-audit	8 vulnerable advisory(ies)	<code>raw_original_result/bundler-audit.txt</code>
 1	Compliance	license_finder	73	<code>raw_original_result/license_finder.txt</code>
 2	Data correctness	active_record_doctor	7 issue(s)	<code>raw_original_result/active_record_doctor.txt</code>
 3	Performance	fasterer	5 speed suggestion(s)	<code>raw_original_result/fasterer.txt</code>
 3	Performance	lol_dba	2 missing index(es)	<code>raw_original_result/lol_dba.txt</code>
 4	Maintainability	rubycritic	score 95.48, 31 smell(s)	<code>raw_original_result/rubycritic.txt</code>
 4	Rails conventions	rails_best_practices	19 warning(s)	<code>raw_original_result/rails_best_practices.txt</code>
 4	Maintainability	rubocop	27 offense(s)	<code>raw_original_result/rubocop.txt</code>
 4	Maintainability	erb_lint	8 ERB offense(s)	<code>raw_original_result/erb_lint.txt</code>
 5	Tech debt	bundle outdated	2	<code>raw_original_result/outdated.txt</code>

Legend —  must fix (security / data) ·  should fix (correctness / maintainability) ·  nice to have (style / freshness).

A  skipped check is NOT a pass. It means the tool could not run in this environment, not that there is nothing wrong. `license_finder` needs a real `bundle install`; `bundle outdated` needs the project's own Ruby (this run used a different Ruby than the project pins). Re-run both in the project's environment to get a real result.

2. Action plan

How to read this — cut noise with confidence/criticality: static tools over-report. brakeman tags each warning High / Medium / Weak confidence — fix the **High** ones first; Weak ones are often false positives. bundler-audit tags each advisory Critical / High / Medium — triage **Critical/High**, don't treat all 100+ as equal. So a raw count (e.g. "137 advisories") is a starting point, not 137 separate jobs.

Severity first. Cover every  and  finding (one row each); collapse the  style-level findings into a single row. Use `<br>` for line breaks inside a cell.

#	Pr i	Issue (tool, file:line)	Solution	Ef fo rt	Raw
1		SQL injection (brakeman) — <code>products_controller.rb:8,10</code> , <code>views/products/index.html.erb:4</code> : <code>Product.where("name LIKE '#{params[:q]}%')"</code> and a raw <code>connection.execute</code> interpolate params straight into SQL.	Use bind params: <code>where("name LIKE ?", "%#{params[:q]}%")</code> ; drop the raw <code>execute</code> for an AR query.	S	<code>raw_original_result/brakeman.txt</code>
2		Command injection (brakeman) — <code>products_controller.rb:28</code> : <code>system("convert #{params[:thumb]} ...")</code> shells out with a user param.	Pass args as a list (<code>system("convert", path, ...)</code>) and validate/whitelist the input; better, use a Ruby image lib.	S	<code>raw_original_result/brakeman.txt</code>
3		XSS (brakeman) — <code>views/products/index.html.erb</code> : <code>params[:q]</code> rendered	Let ERB auto-escape (drop <code>raw / html_safe / <%=</code>);	S	<code>raw_original_res</code>

#	Pr i	Issue (tool, file:line)	Solution	Eff ort	Raw
		unescaped.	escape with <code>h</code> if needed.		ult/brakeman.txt
4	●	Vulnerable gems (bundler-audit) — <code>jwt 2.3.0</code> (CVE-2026-45363, High), <code>rexml 3.2.4</code> (several High/Medium).	Bump <code>jwt >= 3.2.0</code> and <code>rexml >= 3.2.7</code> , then bundle update <code>jwt rexml</code> .	S	raw_original_result/bundler-audit.txt
5	●	Data integrity (active_record_doctor) — missing unique index on <code>products.sku</code> ; NOT NULL missing on <code>products.name</code> , <code>tags.product_id</code> ; no FKs on <code>products.owner_id</code> , <code>tags.product_id</code> .	One migration: <code>add_index ... unique, change_column _null, add_foreign_key</code> (plus the indexes in #8).	M	raw_original_result/active_record_doctor.txt
6	●	License approvals (license_finder) — 73 deps unapproved.	Almost all MIT/BSD — approve the permissive set once (<code>license_finder permitted_licenses add MIT "Simplified BSD" ...</code>); review anything else.	M	raw_original_result/license_finder.txt
7	●	Slow idioms (fasterer) — <code>report.rb:6 select.first</code> , <code>report.rb:16 reverse.each</code> , <code>Hash#fetch</code> with a 2nd arg in <code>puma.rb / production.rb</code> .	<code>detect</code> , <code>reverse_each</code> , and <code>fetch(k) { default }</code> block form.	S	raw_original_result/fasterer.txt
8	●	Missing indexes (lol_dba) — no index on <code>products.owner_id</code> , <code>tags.product_id</code> .	<code>add_index :products, :owner_id</code> and <code>add_index :tags, :product_id</code> (fold into #5's migration).	S	raw_original_result/lol_dba.txt
9	●	Rails conventions (rails_best_practices) — 19 warnings: Law of Demeter in <code>index.html.erb</code> , fat-controller logic, <code>rescue Exception</code> at <code>products_controller.rb:35</code> , unused <code>Product / Report</code> methods, unrestricted routes.	Push logic into models, <code>rescue StandardError</code> , delete dead methods, scope routes with <code>only: .</code>	M	raw_original_result/rails_best_practices.txt

#	Pr i	Issue (tool, file:line)	Solution	Ef fo rt	Raw
10	🟡	Maintainability (rubycritic) — score 95.48, 31 smells; <code>report.rb</code> worst (5 smells).	Refactor the flagged duplication/complexity, starting with <code>report.rb</code> .	M	<code>raw_original_result/rubycritic.txt</code>
11	⬜	Style + freshness (rubocop 27 / erb_lint 8 / bundle outdated) — mostly autocorrectable; gems jwt & rexml outdated (covered in #4).	<code>rubocop -A</code> and <code>erblint -a</code> for the autocorrectable set; review the rest.	S	<code>raw_original_result/rubocop.txt</code>

3. Still to run manually

Runtime data-correctness & missing-index checks **ran** (2026-06-23 15:49) and are folded into the Overview and Action plan above — full per-detector output is in

`raw_original_result/active_record_doctor.txt` and
`raw_original_result/lol_dba.txt`.

Two checks still need the app *exercised* (not just booted), so run them by hand:

- **N+1 queries** — add `gem "bullet"` (development/test), enable it in `config/environments/test.rb`, then run your request/system specs; Bullet logs every N+1.
- **Test coverage** — add `gem "simplecov", require: false` (test), put `require "simplecov"; SimpleCov.start "rails"` at the top of your test helper, run the suite (`bin/rails test` or `bundle exec rspec`), then open `coverage/index.html`.